ISO 27001 Risk Assessment Project

NovaPay Fintech Ltd

Executive Summary

NovaPay Fintech Ltd is a digital financial services organization that provides online payment processing and financial transaction services to its customers. Due to the sensitive nature of financial and personal data processed by the organization, maintaining strong information security controls is critical to ensuring operational resilience and protecting customer trust.

This project presents a structured information security risk assessment conducted in alignment with the principles of an Information Security Management System (ISMS) as defined by International Organization for Standardization ISO/IEC 27001.

The objective of this assessment is to identify critical organizational assets, evaluate potential threats and vulnerabilities, determine the likelihood and impact of security risks and propose appropriate risk treatment strategies.

The findings of this risk assessment highlight several key risks that could affect NovaPay's operations, including unauthorized access to financial systems, data breaches involving customer information, malware infections affecting employee workstations and misconfigurations within cloud infrastructure.

To mitigate these risks, the organization must implement appropriate technical and administrative controls, including stronger access control mechanisms, multi-factor authentication, endpoint protection, cloud security monitoring and improved user privilege management.

This assessment supports NovaPay's broader security governance framework and contributes to the ongoing improvement of its Information Security Management System.

Project Overview

This project simulates how organizations perform information security risk assessments as part of their governance, risk and compliance (GRC) programs.

The risk assessment follows a structured methodology that includes identifying organizational assets, analyzing threats and vulnerabilities, evaluating risk levels and recommending appropriate mitigation strategies.

The purpose of this project is to demonstrate practical knowledge of information security risk management and to illustrate how organizations apply structured risk assessment processes to protect critical information assets.

This project forms part of a cybersecurity portfolio designed to demonstrate foundational GRC capabilities relevant to entry-level roles in information security, risk management and compliance.

Organization Background

NovaPay Fintech Ltd is a fictional financial technology company that provides digital payment solutions and online financial transaction services.

The organization relies heavily on cloud-based infrastructure, web applications and internal networks to support its operations. As a fintech organization, NovaPay processes sensitive financial and personal information belonging to its customers.

Because of this, the organization must maintain strong information security practices to ensure the confidentiality, integrity and availability of its systems and data.

Risk Assessment Methodology

The risk assessment methodology used in this project follows common risk management practices recommended by International Organization for Standardization ISO/IEC 27001.

The process includes the following steps:

1. Asset Identification
2. Threat Identification
3. Vulnerability Identification
4. Risk Analysis
5. Risk Evaluation
6. Risk Treatment Planning

Each step helps the organization understand potential security risks and determine the most appropriate controls to reduce risk exposure.

Asset Identification

1 Purpose

Asset identification is a critical step in the risk assessment process because it helps the organization understand which systems, data and resources must be protected. Identifying key assets allows the organization to evaluate potential threats and vulnerabilities that could impact the confidentiality, integrity and availability of its information.

For NovaPay Fintech Ltd, assets include digital systems, sensitive data, infrastructure and devices that support the organization’s financial services operations.

The identification of these assets enables the organization to prioritize security controls and allocate resources effectively to protect critical business operations.

2 Asset Identification Approach

To identify relevant assets, the following categories were considered:

- Information assets (data and records)
- Technology assets (systems, applications, infrastructure)
- Physical assets (devices and hardware)
- Network assets (communication infrastructure)

These assets were selected based on their importance to NovaPay's core financial services operations and their potential impact on business continuity if compromised.

3 Identified Organizational Assets

The following key assets were identified as critical to NovaPay Fintech Ltd's operations.

Asset ID	Asset Name	Description	Asset Owner	Importance
A1	Customer Database	Stores customer personal information, financial records, and transaction history	IT Department	Critical
A2	Payment Processing System	Handles customer payment transactions and financial transfers	Finance / IT	Critical
A3	Cloud Infrastructure	Hosts company applications and data storage services	IT Department	High
A4	Employee Workstations	Devices used by employees to access company systems and perform daily operations	IT Department	Medium
A5	Internal Network	Network infrastructure that connects organizational systems and devices	IT Department	High

4 Asset Importance Classification

Each asset was classified based on its importance to NovaPay's operations and the potential business impact if the asset were compromised.

Assets classified as **Critical** represent systems that directly support financial transactions and customer data processing. Any compromise of these assets could lead to financial loss, regulatory violations or reputational damage.

Assets classified as **High** support core infrastructure and operational capabilities. While not directly involved in transaction processing, disruptions to these assets could significantly impact the organization's ability to operate effectively.

Assets classified as **Medium** represent supporting resources that are necessary for day-to-day operations but may have a lower impact compared to core financial systems.

Threat Identification

1 Purpose

Threat identification involves determining potential events or actions that could exploit vulnerabilities and cause harm to organizational assets. These threats may originate from external attackers, internal employees, system failures or environmental factors.

For NovaPay Fintech Ltd, identifying relevant threats is critical due to the sensitive financial and personal information processed by the organization. Understanding these threats helps the organization implement appropriate security controls to reduce the likelihood of security incidents.

2 Threat Identification Approach

Threats were identified by analyzing the critical assets of the organization and considering common cybersecurity risks that affect financial technology companies.

The following threat sources were considered during this assessment:

- External cyber attackers
- Insider threats (employees or contractors)
- Malware and ransomware attacks
- Phishing and social engineering
- System misconfigurations
- Technology failures

These threat sources represent common risks faced by organizations operating in cloud-based and digital financial environments.

3 Identified Threats

The following threats were identified as relevant to NovaPay Fintech Ltd's operations.

Threat ID	Threat Name	Description	Target Asset
T1	Data Breach	Unauthorized access to sensitive customer information	Customer Database
T2	Unauthorized System Access	Attackers gaining access to internal systems without proper authorization	Payment Processing System

Threat ID	Threat Name	Description	Target Asset
T3	Malware Infection	Malicious software infecting employee devices and spreading across the network	Employee Workstations
T4	Phishing Attack	Attackers tricking employees into revealing credentials or sensitive information	Employee Accounts
T5	Cloud Misconfiguration	Improper cloud security settings exposing sensitive data	Cloud Infrastructure
T6	Insider Threat	Employees misusing access privileges intentionally or accidentally	Internal Systems
T7	Distributed Denial of Service (DDoS)	Attackers overwhelming systems to disrupt services	Payment Platform
T8	Ransomware Attack	Attackers encrypting company data and demanding payment for recovery	Organizational Systems
T9	Credential Theft	Stolen usernames and passwords used to access systems	Employee Accounts
T10	System Failure	Hardware or software failures affecting system availability	Internal Infrastructure

Vulnerability Identification

1 Purpose

Vulnerability identification involves identifying weaknesses in systems, processes or controls that could be exploited by threats to compromise the confidentiality, integrity or availability of organizational assets.

Understanding vulnerabilities allows the organization to implement appropriate security controls and reduce the likelihood of successful attacks.

For NovaPay Fintech Ltd, vulnerabilities may arise from technical weaknesses, misconfigured systems, insufficient security controls or human-related factors such as lack of awareness or improper access management.

2 Vulnerability Identification Approach

Vulnerabilities were identified by evaluating the organization’s key assets and considering common security weaknesses that may exist in financial technology environments.

The assessment considered vulnerabilities across the following areas:

- Access control weaknesses
- System configuration issues
- Lack of security monitoring
- Human factors such as phishing susceptibility
- Inadequate security updates and patching

These vulnerabilities represent realistic weaknesses that could allow identified threats to impact NovaPay's systems and information assets.

3 Identified Vulnerabilities

The following vulnerabilities were identified in relation to previously identified threats and assets.

Vulnerability ID	Vulnerability	Description	Associated Threat
V1	Weak Access Controls	Lack of strict user access restrictions for sensitive systems	Data Breach
V2	Absence of Multi-Factor Authentication	Users authenticate using only passwords	Unauthorized System Access
V3	Outdated Antivirus Software	Employee devices may lack updated endpoint protection	Malware Infection
V4	Lack of Phishing Awareness Training	Employees may fall victim to phishing attacks	Phishing Attack
V5	Misconfigured Cloud Storage	Improper cloud configuration exposing sensitive data	Cloud Misconfiguration
V6	Excessive User Privileges	Employees may have unnecessary access rights	Insider Threat
V7	Insufficient Network Monitoring	Lack of tools to detect abnormal traffic patterns	DDoS Attack
V8	Lack of Data Backup Strategy	Inadequate backup systems for recovering data	Ransomware Attack
V9	Weak Password Policies	Use of simple or reused passwords	Credential Theft
V10	Lack of Redundant Systems	No backup infrastructure for system failures	System Failure

Risk Analysis and Evaluation

1 Purpose

Risk analysis and evaluation involve determining the potential impact of identified threats and vulnerabilities on organizational assets. This process helps organizations prioritize risks and determine which risks require mitigation or treatment.

For NovaPay Fintech Ltd, risk analysis helps identify the most critical threats that could disrupt operations, compromise sensitive financial data or damage the organization's reputation.

2 Risk Assessment Method

This risk assessment uses a **qualitative risk analysis approach** based on two key factors:

Likelihood – The probability that a threat will exploit a vulnerability.

Impact – The potential damage to the organization if the risk occurs.

Each factor is rated using the following scale:

Likelihood Scale

Rating	Description
Low	Unlikely to occur
Medium	Possible occurrence
High	Likely to occur

Impact Scale

Rating	Description
Low	Minimal disruption to operations
Medium	Noticeable operational impact
High	Severe operational or financial damage

The overall **risk level** is determined by combining likelihood and impact ratings.

3 Risk Evaluation Matrix

Likelihood	Impact	Risk Level
High	High	Critical
High	Medium	High
Medium	High	High
Medium	Medium	Medium
Low	Medium	Low
Low	Low	Low

This matrix helps the organization prioritize risks that require immediate mitigation.

4 Risk Register

The following table summarizes the identified risks, their likelihood, impact and overall risk level.

Risk ID	Asset	Threat	Vulnerability	Likelihood	Impact	Risk Level
R1	Customer Database	Data Breach	Weak Access Controls	High	High	Critical
R2	Payment System	Unauthorized Access	No MFA	Medium	High	High
R3	Employee Workstations	Malware Infection	Outdated Antivirus	High	Medium	High
R4	Employee Accounts	Phishing	Lack of Awareness Training	High	Medium	High
R5	Cloud Infrastructure	Cloud Misconfiguration	Misconfigured Storage	Medium	High	High
R6	Internal Systems	Insider Threat	Excessive Privileges	Medium	High	High
R7	Payment Platform	DDoS Attack	Lack of Network Monitoring	Medium	Medium	Medium
R8	Organizational Systems	Ransomware	Lack of Backups	High	High	Critical
R9	Employee Accounts	Credential Theft	Weak Password Policy	Medium	Medium	Medium
R10	Internal Infrastructure	System Failure	Lack of Redundant Systems	Low	High	Medium

Risk Treatment Plan

1 Purpose

The purpose of risk treatment is to define appropriate actions that reduce the likelihood or impact of identified risks to an acceptable level. Risk treatment ensures that the organization implements security controls that protect critical assets and support secure business operations.

For NovaPay Fintech Ltd, the risk treatment plan focuses on mitigating high and critical risks that could significantly impact financial systems, customer data and business continuity.

2 Risk Treatment Strategies

Organizations generally manage risks using one of the following strategies:

Strategy	Description
Mitigate	Implement controls to reduce the likelihood or impact of the risk
Avoid	Eliminate the activity causing the risk
Transfer	Shift the risk to another party (e.g., insurance or vendors)
Accept	Acknowledge the risk when it falls within acceptable levels

For this assessment, NovaPay primarily focuses on **risk mitigation through the implementation of security controls**.

3 Risk Treatment Plan

The following table outlines recommended actions for addressing identified risks.

Risk ID	Risk Description	Risk Level	Treatment Strategy	Recommended Controls
R1	Customer data breach due to weak access controls	Critical	Mitigate	Implement role-based access control and regular access reviews
R2	Unauthorized access to payment system	High	Mitigate	Implement multi-factor authentication
R3	Malware infection on employee workstations	High	Mitigate	Deploy endpoint protection and automatic security updates

Risk ID	Risk Description	Risk Level	Treatment Strategy	Recommended Controls
R4	Employees falling victim to phishing attacks	High	Mitigate	Conduct regular security awareness training
R5	Cloud data exposure due to misconfiguration	High	Mitigate	Implement cloud security monitoring and configuration audits
R6	Insider misuse of system privileges	High	Mitigate	Apply least privilege access and monitor user activity
R7	Service disruption from DDoS attack	Medium	Mitigate	Deploy network traffic monitoring and DDoS protection services
R8	Data loss from ransomware attack	Critical	Mitigate	Implement regular data backups and recovery procedures
R9	Credential theft from weak password policies	Medium	Mitigate	Enforce strong password policies and password management tools
R10	System outages due to infrastructure failure	Medium	Mitigate	Implement system redundancy and disaster recovery planning

Conclusion

The information security risk assessment conducted for NovaPay Fintech Ltd identified several risks that could potentially impact the confidentiality, integrity and availability of the organization's critical information assets.

Through the structured assessment process, key organizational assets were identified and evaluated against relevant threats and vulnerabilities. The analysis revealed several high and critical risks, including potential customer data breaches, ransomware attacks, unauthorized access to financial systems and cloud infrastructure misconfigurations.

To address these risks, the organization must implement appropriate security controls such as strong access control mechanisms, multi-factor authentication, endpoint protection, cloud security monitoring, employee security awareness training and reliable data backup solutions.

Implementing these controls will significantly reduce the likelihood and potential impact of security incidents while improving the overall security posture of the organization.

This risk assessment supports NovaPay Fintech Ltd's broader information security governance strategy and contributes to the continuous improvement of its Information Security Management System (ISMS).

Regular risk assessments, monitoring activities and policy reviews should be conducted to ensure that emerging threats and vulnerabilities are effectively managed.